

MASS ASSIGNMENT TESTING AND EXTRA FIELD REJECTION

Unexpected JSON field injection and server-side schema validation review

Field	Details
Module	Sub-Project 2 - API Security Testing Lab
Document Type	Individual API Security Methodology PDF
Phase / Test Case	Phase 7 - Mass Assignment Testing
Prepared For	GitHub Portfolio Documentation
Prepared By	Jagriti Banerjee
Repository	Enterprise-Security-Assessment-Lab
GitHub Filename	07-mass-assignment-testing-methodology-report.pdf

This document is a professional, evidence-driven explanation of one API security methodology section. It is designed for portfolio review and contains only authorized lab-based testing context. Sensitive token values, account data, cookies, and private identifiers are redacted or intentionally represented with placeholders.

1. Section Overview

Area	Details
Phase	Phase 7 - Mass Assignment Testing
Objective	Check whether the API accepts unexpected sensitive fields such as role, isAdmin, or privilege flags in a client-controlled JSON body.
Primary Result	Evidence captured and methodology documented
GitHub Folder	02-api-security/reports/methodology/

Why this section matters

The evidence should be treated as control validation. The API rejected the malicious extra fields, which means this specific attempt did not confirm mass assignment vulnerability.

2. Evidence Embedded in This PDF

Evidence 1: 09-mass-assignment-extra-fields-rejected.png

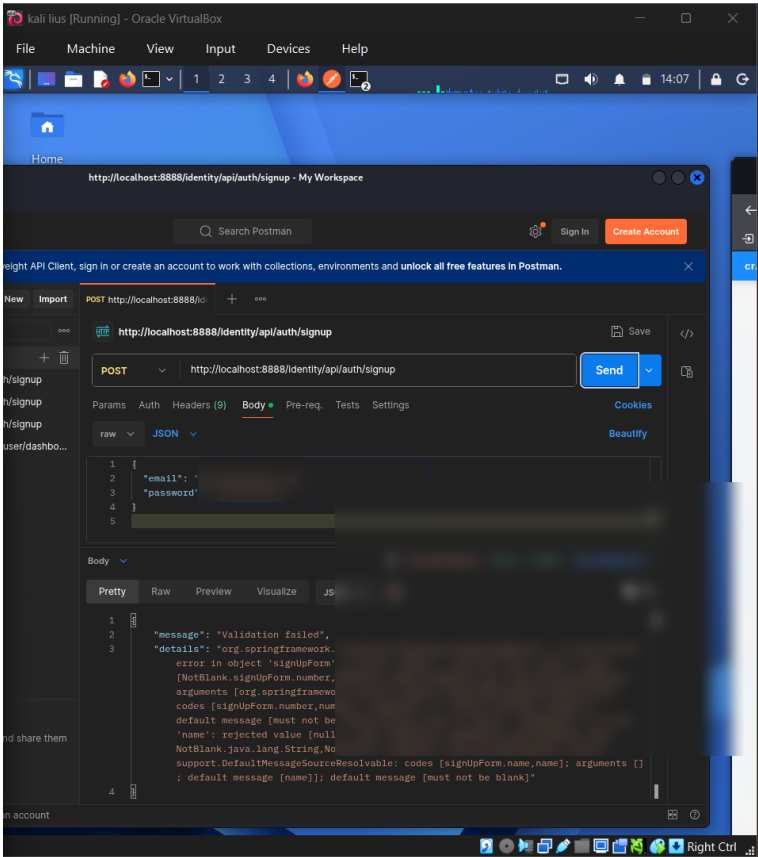


Figure 1 - Evidence showing mass assignment-style extra fields were rejected by the API.

Evidence showing mass assignment-style extra fields were rejected by the API.

3. Command and Workflow Used

```
POST /identity/api/auth/signup
Content-Type: application/json
```

```
{
  "name": "Lab User",
  "email": "lab-user@example.com",
  "password": "REDACTED",
  "role": "admin",
  "isAdmin": true
}
```

```
# Expected secure result:
# Extra fields are ignored or rejected. Privileged attributes are not set.
```

Step-by-step workflow

- Identified an endpoint that accepts JSON input.
- Added unexpected sensitive fields to the request body.
- Submitted the modified request in the lab environment.
- Observed whether the API accepted, ignored, or rejected the fields.
- Captured evidence showing the control outcome.

4. Professional Interpretation

The evidence should be treated as control validation. The API rejected the malicious extra fields, which means this specific attempt did not confirm mass assignment vulnerability.

5. Security Risk and Impact

If mass assignment is present, attackers may set fields such as role=admin, isAdmin=true, credit, balance, userId, or accountStatus. This can lead to privilege escalation or unauthorized business logic changes.

6. Recommended Remediation and Hardening

- Use explicit allowlists for accepted request fields.
- Separate external request models from internal database models.
- Reject unknown or privileged fields in client requests.
- Apply schema validation on every JSON body.
- Write negative tests for role, isAdmin, and privilege-related attributes.

7. Framework Mapping

Framework Area	Mapping
OWASP API	API3 / API6 depending endpoint and business flow

Framework Area	Mapping
Security Control	Schema validation and field allowlisting
Evidence Result	Attack rejected / control validated

8. Sanitized Output Style for GitHub

When documenting this evidence publicly, use placeholders instead of live values. The goal is to prove methodology and security understanding without exposing secrets or private data.

```
Authorization: Bearer <REDACTED_TOKEN>
Cookie: <REDACTED_COOKIE>
email: lab-user@example.com
password: REDACTED
object_id: <CONTROLLED_LAB_ID>
redirect_uri: <REDACTED_OR_LAB_CALLBACK>
```

9. GitHub Redaction Checklist

- Bearer tokens and JWT values must be blurred or replaced with <REDACTED_TOKEN>.
- Email addresses, phone numbers, user IDs, and object identifiers should be blurred when they are not required for understanding the evidence.
- Authorization headers, cookies, session values, OAuth codes, refresh tokens, access tokens, and client secrets must never be visible in public GitHub screenshots.
- If a screenshot contains personally identifiable data, crop the view or blur the affected rows before publication.

10. Publication Note

This report is designed for GitHub portfolio use. It describes authorized lab testing only and avoids production claims. The embedded screenshots have been treated as lab evidence and should remain redacted before upload.